GRI STANDARDS

GRI 418: Privacidade do Cliente 2016

DATA DE VIGÊNCIA: 01 DE JULHO DE 2018

NORMA TEMÁTICA

418

GRI 418: Privacidade do Cliente 2016

Norma Temática

Data de vigência
Esta Norma entrará em vigor para relatórios ou outros materiais publicados a partir de 01 de julho de 2018

Responsabilidade
Esta Norma é uma publicação do Global Sustainability Standards Board (GSSB). Comentários sobre as Normas GRI poderão ser enviados para gssbsecretariat@globalreporting.org para apreciação pelo GSSB.

Devido Processo
Este documento é de interesse público e foi desenvolvido em conformidade com os requisitos do Protocolo de Devido Processo do GSSB. Foi desenvolvido fazendo uso da competência multi-stakeholder e considerando instrumentos intergovernamentais reconhecidos internacionalmente, bem como as amplas expectativas das organizações no que se refere a responsabilidades sociais, ambientais e econômicas.

Responsabilidade legal
O presente documento tem por objetivo promover o relato de sustentabilidade e foi desenvolvido pelo Global Sustainability Standards Board (GSSB) por meio de um processo consultivo singular que envolveu diversos stakeholders, entre os quais representantes de organizações e usuários de informações de relatórios de todo o mundo. Embora o Conselho Diretor da GRI e o GSSB incentivem o uso das Normas GRI para Relato de Sustentabilidade (Normas GRI) e suas Interpretações por todas as organizações, a elaboração e publicação de relatórios total ou parcialmente baseados nas Normas GRI e suas Interpretações são de total responsabilidade de quem os produz. Nem o Conselho Diretor da GRI, nem o GSSB, nem a Fundação Global Reporting Initiative (GRI) podem assumir a responsabilidade por quaisquer consequências ou danos que resultem, direta ou indiretamente, do uso das Normas GRI e suas Interpretações na elaboração de relatórios ou do uso de relatórios baseados nas Normas GRI e suas Interpretações.

Aviso de direitos autorais e marca registrada
Os direitos autorais deste documento pertencem à Fundação Global Reporting Initiative (GRI). Sua reprodução e distribuição para fins informativos e/ou utilização na elaboração de um relatório de sustentabilidade são permitidas sem prévia autorização por parte da GRI. Entretanto, nem este documento, nem qualquer parte dele poderão ser reproduzidos, arquivados, traduzidos ou transferidos, em qualquer forma ou mídia (eletrônica, mecânica, fotocopiada, gravada, etc.), para qualquer outro fim sem autorização prévia da GRI.

Global Reporting Initiative, GRI e seu logotipo, GSSB e seu logotipo e Normas GRI para Relato de Sustentabilidade (Normas GRI) e seu logotipo são marcas registradas da Fundação Global Reporting Initiative.

© 2023 GRI. All rights reserved.

Sumário

Introdução 4

1. Conteúdos para gestão de temas 7

2. Conteúdos temáticos 8

Conteúdo 418-1 Queixas comprovadas relativas a violação da privacidade e perda de dados de clientes 8

Glossário 9

Bibliografia 11

Introdução

A Norma *GRI 418: Privacidade do Cliente 2019* possui conteúdos para que as organizações relatem informações sobre seus impactos relacionados a privacidade do cliente, e sobre como elas gerenciam esses impactos.

A Norma está estruturada da seguinte forma:

- A Seção 1 contém um requisito que fornece informações sobre como a organização gerencia seus impactos relacionados a privacidade do cliente.
- A Seção 2 possui um conteúdo que fornece informações sobre os impactos da organização relacionados a privacidade do cliente.
- O Glossário contém termos definidos com um significado específico quando usados nas Normas GRI. Os termos estão sublinhados no texto das Normas GRI, com links para suas definições.
- A Bibliografia contém os instrumentos intergovernamentais reconhecidos internacionalmente que foram usados no desenvolvimento desta Norma.

O restante da Introdução apresenta informações gerais sobre o tema, uma visão geral do sistema das Normas GRI e outras informações sobre como usar esta Norma.

Informações gerais sobre o tema

Esta Norma aborda o tema privacidade do cliente, incluindo perda de dados de clientes e violação da privacidade do cliente. Isso pode resultar da não conformidade com leis, regulamentos e/ou outras normas voluntárias existentes referentes à proteção da privacidade do cliente.

Esses conceitos são abordados em importantes publicações da Organização para a Cooperação e o Desenvolvimento Econômico: consulte a Bibliografia.

Sistema das Normas GRI

Esta Norma é parte das Normas GRI para Relato de Sustentabilidade (Normas GRI). As Normas GRI permitem que uma organização relate informações sobre os seus impactos mais significativos na economia, no meio ambiente e nas pessoas, inclusive impactos nos direitos humanos, e sobre como a organização gerencia esses impactos.

As Normas GRI são estruturadas como um sistema de normas inter-relacionadas, organizadas em três séries: Normas Universais da GRI, Normas Setoriais da GRI e Normas Temáticas da GRI (consulte a Figura 1 desta Norma).

Normas Universais: GRI 1, GRI 2 e GRI 3

A Norma *GRI 1: Fundamentos 2021* especifica os requisitos que a organização deve cumprir para relatar em conformidade com as Normas GRI. A organização inicia o uso das Normas GRI consultando a Norma *GRI 1*.

A Norma *GRI 2: Conteúdos Gerais 2021* possui conteúdos que a organização usa para fornecer informações sobre suas práticas de relato e outros detalhes da organização, tais como suas atividades, sua governança e suas políticas.

A Norma *GRI 3: Temas Materiais 2021* fornece orientações sobre como definir temas materiais. Ela também possui conteúdos que a organização usa para relatar informações sobre seu processo de definição de temas materiais, sua lista de temas materiais e como ela gerencia cada tema.

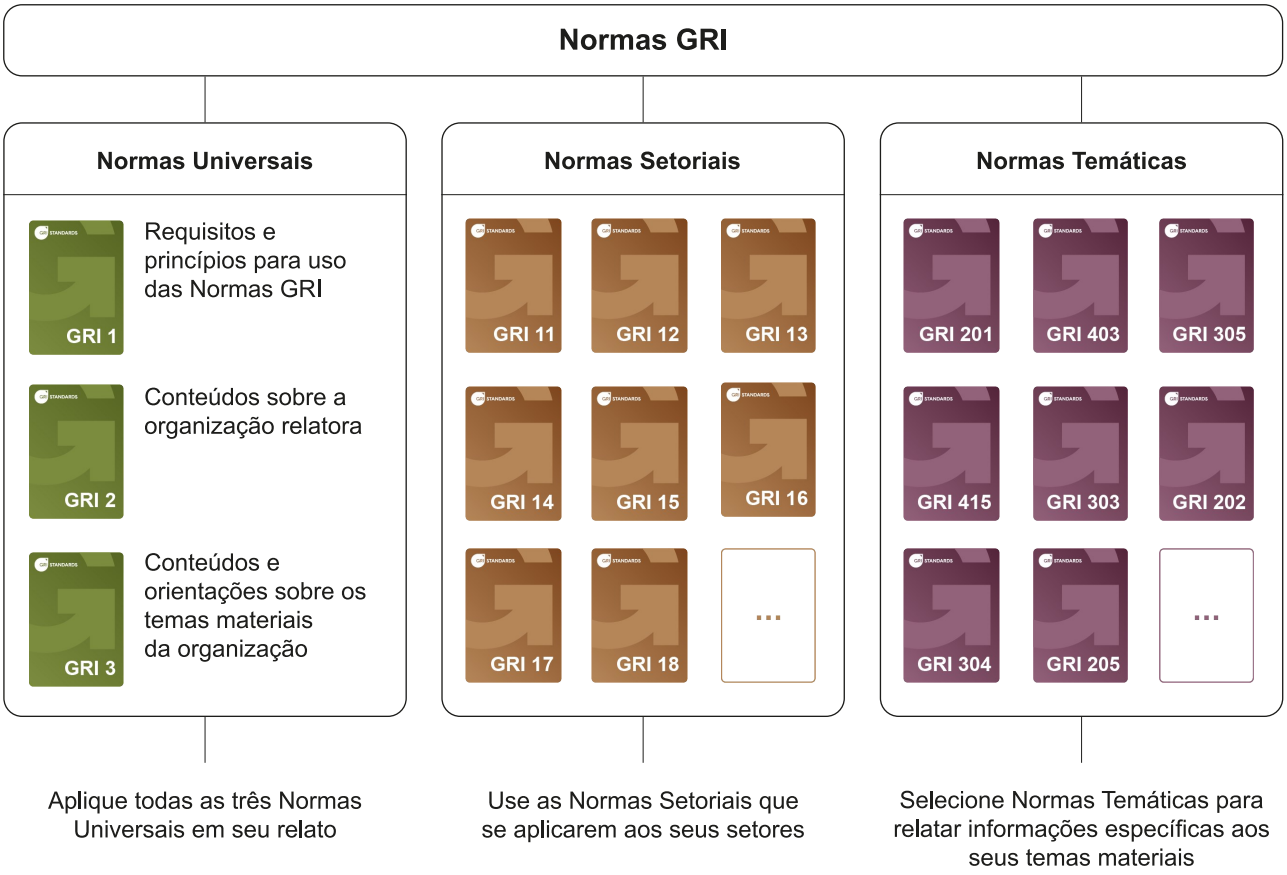
Normas Setoriais

As Normas Setoriais fornecem informações para as organizações sobre seus prováveis temas materiais. A organização usa as Normas Setoriais que se aplicam a seus setores ao definir seus temas materiais e ao definir o que relatar para cada tema material.

Normas Temáticas

As Normas Temáticas possuem conteúdos que a organização usa para relatar informações sobre seus impactos em relação a temas em particular. A organização usa as Normas Temáticas de acordo com a lista de temas materiais que definiu usando a Norma *GRI 3*.

Figura 1. Normas GRI: Normas Universais, Setoriais e Temáticas



Uso desta Norma

Qualquer organização poderá usar esta Norma - independentemente de porte, tipo, setor, localização geográfica ou experiência com relato - para relatar informações sobre seus impactos relacionados a privacidade do cliente.

É necessário que a organização que estiver relatando em conformidade com as Normas GRI relate os conteúdos abaixo se ela tiver definido que privacidade do cliente é um tema material:

- Conteúdo 3-3 da Norma *GRI 3: Temas Materiais 2021* (consulte o item 1.1 desta Norma);
- Quaisquer conteúdos desta Norma Temática que sejam relevantes para os impactos da organização relacionados a privacidade do cliente (Conteúdo 418-1).

Consulte os Requisitos 4 e 5 da Norma *GRI 1: Fundamentos 2021*.

Motivos para omissão são permitidos para esses conteúdos.

Se a organização não puder cumprir com um conteúdo ou um requisito em um conteúdo (ex.: porque a informação necessária é confidencial ou sujeita a proibições legais), então é necessário que a organização especifique o conteúdo ou o requisito que não pode cumprir e apresente um motivo para omissão com uma explicação no sumário de conteúdo da GRI. Consulte o Requisito 6 da Norma *GRI 1: Fundamentos 2021* para mais informações sobre motivos para omissão.

Se a organização não puder relatar as informações necessárias sobre um item especificado em um conteúdo porque o item (ex.: comitê, política, prática ou processo) não existe, ela poderá cumprir o requisito relatando que este é o caso. A organização poderá explicar os motivos de não possuir esse item ou descrever possíveis planos para criá-lo. O conteúdo não exige que a organização implemente o item (ex.: criar uma política), mas é necessário relatar que o item não existe.

Se a organização pretende publicar um relatório de sustentabilidade avulso, ela não precisa repetir as informações que já relatou publicamente em outro lugar, como páginas da Internet ou em seu relatório anual. Nesse caso, a organização poderá relatar um conteúdo necessário fornecendo uma referência no sumário de conteúdo da GRI de onde esta informação poderá ser encontrada (ex.: inserindo um link para a página da Internet ou citando a página no relatório anual onde a informação tenha sido publicada).

Requisitos, orientações e termos definidos
O seguinte se aplica ao longo desta Norma:

Requisitos são apresentados em **negrito** e indicados pela palavra "deverá". A organização deve cumprir requisitos para relatar em conformidade com as Normas GRI.

Os requisitos podem estar acompanhados por orientações.

Orientações incluem informações gerais, explicações e exemplos para ajudar as organizações a entender melhor os requisitos. Não é exigido que a organização cumpra as orientações.

As Normas poderão também incluir recomendações. Esses são casos em que uma ação específica é incentivada, mas não exigida.

As expressões “recomenda-se que” ou “é recomendada(o) a” indicam uma recomendação e as palavras "pode(m)" ou “poderá(ão)” indicam uma possibilidade ou opção.

Os termos definidos estão sublinhados no texto das Normas GRI, com links para suas definições no Glossário. É necessário que a organização aplique as definições do Glossário.

1. Conteúdos para gestão de temas

É necessário que a organização que estiver relatando em conformidade com as Normas GRI relate como gerencia seus temas materiais.

É necessário que a organização que tenha definido que privacidade do cliente é um tema material relate como gerencia o tema usando o Conteúdo 3-3 da Norma *GRI 3: Temas Materiais 2021* (consulte o item 1.1 desta seção).

Esta seção visa, portanto, complementar – e não substituir – o Conteúdo 3-3 da Norma *GRI 3*.

REQUISITOS

1.1 A organização relatora deverá relatar como gerencia privacidade do cliente usando o Conteúdo 3-3 da Norma *GRI 3: Temas Materiais 2021*.

2. Conteúdos temáticos

Conteúdo 418-1 Queixas comprovadas relativas a violação da privacidade e perda de dados de clientes

REQUISITOS

A organização relatora deverá relatar as seguintes informações:

a. Número total de queixas comprovadas relativas a violação da privacidade do cliente, categorizadas por:

i. queixas recebidas de partes externas e comprovadas pela organização;
ii. queixas de agências reguladoras.

b. Número total de vazamentos, furtos ou perdas de dados de clientes que foram identificados.

c. Se a organização não tiver identificado nenhuma queixa comprovada, uma breve declaração desse fato será suficiente.

Requisitos para compilação

2.1 Ao compilar as informações especificadas no Conteúdo 418-1, a organização relatora deverá indicar se um número significativo dessas queixas se refere a eventos em anos anteriores.

ORIENTAÇÕES

Informações gerais

A proteção da privacidade do cliente é um objetivo geralmente reconhecido em leis nacionais e políticas organizacionais. Conforme definido nas *Diretrizes da OCDE para Empresas Multinacionais*, da Organização para a Cooperação e o Desenvolvimento Econômico (OCDE), espera-se que as organizações "respeitem a privacidade do consumidor e adotem medidas razoáveis para garantir a segurança dos dados pessoais que coletam, armazenam, processam ou disseminam".

Para proteger a privacidade do cliente, espera-se que a organização limite a coleta de dados pessoais, colete dados por meios legais e seja transparente sobre como os dados são reunidos, usados e protegidos. Espera-se, também, que a organização não revele nem use informações pessoais dos clientes para quaisquer fins além dos acordados e que comunique diretamente aos clientes quaisquer mudanças nas políticas ou medidas de proteção de dados.

Este conteúdo fornece uma avaliação do sucesso dos sistemas e procedimentos de gestão relacionados à proteção da privacidade do cliente.

Glossário

Este glossário inclui definições de termos usados nesta Norma. É necessário que a organização aplique essas definições ao usar as Normas GRI.

As definições inclusas neste glossário podem conter termos que estejam, por sua vez, definidos no *Glossário das Normas GRI*. Todos os termos definidos estão sublinhados. Quando um termo não estiver definido neste glossário ou no *Glossário das Normas GRI*, definições normalmente usadas e entendidas serão aplicáveis.

desenvolvimento sustentável / sustentabilidade
desenvolvimento que satisfaz as necessidades do presente sem comprometer a capacidade das gerações futuras de suprir suas próprias necessidades

Fonte: Comissão Mundial sobre Meio Ambiente e Desenvolvimento, *Nosso Futuro Comum*, 1987

Obs.: Os termos “sustentabilidade” e “desenvolvimento sustentável” são usados alternadamente nas Normas GRI.

direitos humanos
direitos inerentes a todos os seres humanos, os quais incluem, no mínimo, os direitos previstos na *Carta Internacional dos Direitos Humanos das Nações Unidas* e os princípios referentes aos direitos fundamentais estabelecidos na *Declaração da Organização Internacional do Trabalho (OIT) relativa aos Princípios e Direitos Fundamentais no Trabalho*

Fonte: Organização das Nações Unidas (ONU), *Princípios Orientadores sobre Empresas e Direitos Humanos: Implementando o Quadro das Nações Unidas “Proteger, Respeitar e Remediar”,* 2011; modificado

Obs.: Consulte Orientações para o item 2-23-b-i da Norma *GRI 2: Conteúdos Gerais 2021* para mais informações sobre "direitos humanos".

impacto
efeito que uma organização causa ou poderia causar na economia, no meio ambiente e nas pessoas, inclusive impactos em seus direitos humanos, que, por sua vez, pode indicar sua contribuição (positiva ou negativa) para o desenvolvimento sustentável

Obs. 1: Os impactos poderão ser reais ou potenciais, negativos ou positivos, de curto ou longo prazo, intencionais ou não, e reversíveis ou irreversíveis.

Obs. 2: Consulte a seção 2.1 da Norma *GRI 1: Fundamentos 2021* para mais informações sobre "impacto".

privacidade do cliente
direito do cliente à privacidade e proteção pessoal

Exemplos: a obrigação de respeitar a confidencialidade; a proteção de dados; a proteção das informações ou dados contra uso indevido ou furto; o uso de informações ou dados apenas para a finalidade a que se destinam, salvo acordo específico em contrário

Obs.: Entende-se como cliente tanto os clientes finais (o consumidor) como os clientes B2B (comércio entre empresas).

queixa comprovada
notificação por escrito emitida por agência reguladora ou órgão oficial similar endereçada à organização identificando violações da privacidade do cliente ou queixa apresentada à organização que tenha sido reconhecida como legítima pela organização

temas materiais
temas que representam os impactos mais significativos da organização na economia, no meio ambiente e nas pessoas, inclusive impactos em seus direitos humanos

Obs.: Consulte a seção 2.2 da Norma *GRI 1: Fundamentos 2021* e a seção 1 da Norma *GRI 3: Temas Material 2021* para mais informações sobre "temas materiais".

violação da privacidade do cliente
não conformidade com regulamentos legais e normas (voluntárias) existentes relativos à proteção da privacidade do cliente

Bibliografia

Esta seção lista os instrumentos intergovernamentais reconhecidos internacionalmente que foram usados no desenvolvimento desta Norma.

Instrumentos reconhecidos:

1. Organização para a Cooperação e o Desenvolvimento Econômico (OCDE), *Diretrizes da OCDE para Empresas Multinacionais*, 2011.

Agradecimentos

Beto Bezerril & Martha Villac (Harvest T. I. Ltda-ME) realizaram a tradução deste documento para o português, que foi revisada pelos seguintes especialistas:

- **Daniela Manole**, Fundadora e CEO da Bridge3 Governança & Sustentabilidade (Parceiro de Treinamento GRI), Brasil – Presidente do Comitê de Especialistas
- **Alex Vervuurt**, Sócio-Diretor da 3R Serviços, Brasil
- **Christina Brentano**, Sócia-Diretora da Editora Contadino, Brasil
- **Mariana Nunes da Silva de Carvalho Páscoa**, Engenheira do Ambiente da Transtejo-Soflusa, Portugal

Esta tradução foi patrocinada por:



A GRI gostaria de agradecer o Governo da Suécia por seu apoio financeiro para esta tradução para o português da atualização 2021 das Normas GRI.

Isenção de Responsabilidade

Esta tradução para o português da atualização 2021 das Normas GRI foi financiada pelo Governo da Suécia. Seu criador assume plena e total responsabilidade pelo conteúdo. O Governo da Suécia não necessariamente compartilha das visões e interpretações aqui apresentadas.

As Normas GRI para Relato de Sustentabilidade foram desenvolvidas e preparadas em inglês. A despeito do esforço realizado para assegurar a exatidão desta tradução, o texto em inglês prevalecerá em caso de dúvidas ou discrepâncias decorrentes da tradução. A versão mais recente das Normas GRI em inglês e suas atualizações estão publicadas no site da GRI (www.globalreporting.org).

Esta tradução para o português das Normas GRI foi produzida para auxiliar as organizações que utilizam o português na elaboração do seu relato e para ajudar os usuários de informações que falam o idioma português a obterem uma melhor compreensão das Normas GRI. A tradução visa atender a todos os falantes do português mas, quando houve a necessidade de escolher entre variantes regionais na transmissão de conceitos ou terminologia, os tradutores optaram por expressões comumente utilizadas no português do Brasil.

GRI
PO Box 10039,
1001 EA Amsterdã,
Países Baixos

www.globalreporting.org